

TwinaForms Salesforce Code Analyzer ISV Response

Date: 2026-08-24

Package: TwinaForms managed 2GP package 0.14.0.1

AppExchange / Subscriber Package ID: 033gL0000009ZbFQAU

Subscriber Package Version ID: 04tgL000000009FQAW

Scan Scope

The focused AppExchange Code Analyzer report for the current release candidate is staged with this response:

- security-reports/documentation-upload-2026-08-24-0.14.0.1/code-analyzer/appexchange-security-focused.html
- security-reports/documentation-upload-2026-08-24-0.14.0.1/code-analyzer/appexchange-security-focused.json

The focused report contains 28 Moderate findings and no Critical or High findings.

The findings are keyword-based matches caused by package terminology such as signature , token , key , and secret . The flagged values are not passwords, OAuth refresh tokens, AWS credentials, private keys, or Salesforce user credentials.

Current Finding Summary

Rule	Severity	Count	Disposition
AvoidHardcodedCredentialsInVarAssign	3	14	False positive keyword matches in local variables
AvoidHardcodedCredentialsInVarDecls	3	3	False positive keyword matches in local variables
AvoidHardcodedCredentialsInFieldDecls	3	1	Public algorithm label, not secret material
ProtectSensitiveData	3	10	Public identifiers, public key material, public CAPTCHA site key, or package design metadata

NativeFormsBootstrapV2Signer.SIGNATURE_ALGORITHM

Rule: AvoidHardcodedCredentialsInFieldDecls

Classification: False positive.

`SIGNATURE_ALGORITHM` stores the public algorithm label `HMAC-SHA256`. This is not the HMAC secret, tenant bearer secret, OAuth token, AWS credential, or private key material. The actual signing secret is generated with Salesforce cryptographic APIs and stored in protected package configuration, not hard-coded in Apex.

`NativeFormsDesignerController.placedRowSignature`

Rule: `AvoidHardcodedCredentialsInVarAssign`

Classification: False positive.

`placedRowSignature` is a Boolean layout variable in the form designer. It records whether a signature input element was placed inside a repeat-row container so the designer can apply row-specific signature settings. It stores only `true` or `false`; it never contains a handwritten signature image, cryptographic signature, token, password, or credential.

`NativeFormsDesignerController.objectToken`

Rules: `AvoidHardcodedCredentialsInVarDecls`, `AvoidHardcodedCredentialsInVarAssign`

Classification: False positive.

`objectToken` is a sanitized Salesforce object-name fragment used to construct a readable page-layout import action name. It is derived from an object API name, normalized to alphanumeric and underscore characters, and used only as a label/name component. It is not an authentication token and does not grant access to Salesforce data, AWS endpoints, or package administration.

`NativeFormsPublisher.signatureHtml`

Rules: `AvoidHardcodedCredentialsInVarDecls`, `AvoidHardcodedCredentialsInVarAssign`

Classification: False positive.

`signatureHtml` is generated HTML markup for the published form's signature-capture UI. It contains browser markup such as a canvas, clear button, help text, and validation feedback container. It does not contain cryptographic signatures, stored signature images, secrets, credentials, OAuth tokens, or private key material.

`NativeForms_Config__c.Captcha_Site_Key__c`

Rule: `ProtectSensitiveData`

Classification: Accepted public value.

This field stores a Google reCAPTCHA site key. reCAPTCHA site keys are designed to be rendered to browsers and embedded in public web pages. The corresponding CAPTCHA secret key is not stored in Salesforce package metadata and is not exposed through this field.

`NativeForms_Config__c.Enable_Pro_SF_Secret_Code_Auth__c`

Rule: ProtectSensitiveData

Classification: False positive.

This field is a Boolean feature flag. It stores only `true` or `false`. The phrase `Secret Code` is the customer-facing feature name for an optional verification flow; the field itself contains no code value, password, token, or credential.

`NF_Form__c.NF_Key__c`

Rule: ProtectSensitiveData

Classification: False positive.

This field stores a stable generated form identifier used by TwinaForms to identify a form record across package operations. It is an application identifier, not a password, OAuth token, API secret, bearer credential, or private key.

`NF_Form_Action__c.Command_Key__c`

Rule: ProtectSensitiveData

Classification: False positive.

This field stores a generated command identifier used to map configured prefill and submit actions. It is a design-time/runtime mapping key only. It does not authenticate users, grant Salesforce access, grant AWS access, or bypass package authorization.

`NF_Form_Element__c.Field_Key__c`

Rule: ProtectSensitiveData

Classification: False positive.

This field stores a generated field identifier used to map submitted JSON values to configured form elements. It is not secret and does not provide access to Salesforce records or package administration.

`NF_Form_Publication__c.Publication_Status__c`

Rule: ProtectSensitiveData

Classification: False positive.

This restricted picklist stores publication job state values such as pending, success, or failed. It contains no secret, credential, token, or private security material.

`NF_Form_Publication__c.Publication_Type__c`

Rule: ProtectSensitiveData

Classification: False positive.

This restricted picklist stores the publication operation type, such as publish, republish, unpublish, or register-only. It is not an authentication value and does not grant access.

NF_Form_Version__c.Publish_Token__c

Rule: ProtectSensitiveData

Classification: Accepted per-form public capability value.

This value is scoped to one published public form and is used by TwinaForms backend policy to validate public prefill and submit requests for that form. It is not a Salesforce login credential, OAuth refresh token, AWS credential, cross-tenant token, cross-form token, or package-administration secret. It does not grant access to private Salesforce APIs or other tenant data.

The AWS backend stores server-side policy for published forms and validates requests against that policy. The token is intentionally scoped to the public form artifact and cannot be used as a general credential.

NF_Submission_Log_Key__c.Key_Version__c

Rule: ProtectSensitiveData

Classification: False positive.

This field stores a version label for submission-log cryptography configuration, such as v2 . It is metadata about the key format/version and does not contain key material, credentials, passwords, or access tokens.

NF_Submission_Log_Key__c.Public_Key__c

Rule: ProtectSensitiveData

Classification: Accepted public cryptographic material.

This field stores a public cryptographic key used for submission-log encryption. Public keys are designed to be shared and are not secret. This field does not contain the corresponding private key or any bearer credential.

New 0.14 Features

The current focused Code Analyzer report did not introduce new AppExchange security findings for the 0.14 connected-org import/export work or the Agentforce layout-to-form action.

The Agentforce action creates a TwinaForms draft from Salesforce page-layout metadata and returns draft/version identifiers plus a Designer URL for human review. It does not expose credentials and does not publish a form automatically.

The connected-org import/export feature is documented separately in the product, data-flow, API, and ZAP evidence included in this 0.14 submission packet.

Reviewer Disposition

All focused AppExchange Code Analyzer findings are documented as false positives or accepted public values. No finding in this focused report indicates exposed credentials, exposed OAuth secrets, exposed AWS credentials, private key disclosure, SOQL injection, XSS, CSRF, or insecure endpoint usage.